

DOM XSS in innerHTML Sink Using `location.search`

Vulnerability

DOM-based Cross-Site Scripting (DOM XSS)

Lab

PortSwigger Web Security Academy

Description

The application was vulnerable to DOM-based XSS because user-controlled data from the URL query string (`location.search`) was inserted into an `innerHTML` sink without proper sanitization.

An attacker can inject HTML containing an event handler, causing JavaScript to execute in the victim's browser.

Steps to Reproduce

1. Open the vulnerable lab page.
2. Identify the URL parameter that is reflected into the page.
3. Modify the parameter with the following payload:

```
<img src=1 onerror=alert(1)>
```

4. The payload is processed by the application's `innerHTML` sink.
5. The invalid image triggers the `onerror` event, executing the JavaScript.
6. An alert is displayed, confirming successful DOM XSS.

Payload

```
<img src=1 onerror=alert(1)>
```

Testing Method

- **Burp Suite Repeater**
- No screenshots available

Impact

Successful DOM XSS allows an attacker to execute arbitrary JavaScript in a victim's browser under the security context of the vulnerable application. Depending on the application's functionality, this could enable actions such as modifying page content, performing unauthorized actions, or accessing sensitive information available to the page.

Remediation

- Avoid inserting untrusted data directly into `innerHTML`.
- Prefer safe DOM APIs such as `textContent`.
- Properly validate and encode user-controlled input.
- Apply an appropriate Content Security Policy (CSP) as an additional defense.

OWASP

OWASP Top 10 — A03:2021 Injection

Result

The DOM-based XSS vulnerability was successfully exploited through the `location.search` source and `innerHTML` sink, resulting in JavaScript execution in the browser.